Políticas de Acesso e Identidade (IAM) – Questão 3.2

Preparado por Davi e grupo. Versão com regra + justificativa técnica, autenticação e autorização separadas e Zero Trust como base.

> **Como usar:** onde aparecer **[sistema]** ou **[tipo de dado]**, troque pelos dados reais do projeto do grupo (por exemplo, "o sistema de agendamento da clínica, que guarda dados pessoais dos pacientes"). Assim, cada justificativa fica específica para o projeto, como a questão exige.

Princípio orientador: Zero Trust

Nenhum usuário, dispositivo ou requisição é confiável por padrão. Toda requisição é verificada, mesmo de quem já está logado. As regras abaixo aplicam esse princípio.

A. Regras de autenticação (provar quem é)

1. Todo usuário deve se autenticar com credenciais únicas e individuais, sem contas compartilhadas.

Justificativa: contas compartilhadas impedem saber quem executou cada ação no [sistema], o que inviabiliza auditoria e investigação de incidentes.

2. Contas administrativas e perfis com acesso a [tipo de dado sensível] exigem MFA.

Justificativa: senhas vazam por phishing e reutilização. Um segundo fator impede que a senha sozinha dê acesso ao painel que altera [tipo de dado].

3. Senhas devem ter no mínimo 12 caracteres, ser checadas contra listas de senhas vazadas e ser armazenadas com hash forte (bcrypt/Argon2).

Justificativa: se o banco do [sistema] vazar, hashes fortes dificultam a recuperação das senhas. O tamanho mínimo e a checagem reduzem ataques de dicionário. O NIST (SP 800-63B) recomenda priorizar tamanho em vez de rotação frequente.

4. Após 5 tentativas de login falhas, a conta deve ser bloqueada temporariamente e o evento registrado.

Justificativa: protege contra força bruta e *credential stuffing* na tela de login.

5. Sessões devem expirar por inatividade (ex.: 15 min) e tokens devem ter validade curta, com renovação controlada.

Justificativa: se um dispositivo for esquecido ou um token roubado, a janela de uso indevido é pequena.

6. O sistema deve oferecer Passkeys/FIDO2 como opção de login sem senha.

Justificativa: chaves criptográficas atreladas ao dispositivo são resistentes a phishing, pois não há senha para ser digitada em um site falso.

7. Login social ou corporativo deve usar OIDC (sobre OAuth 2.0) com PKCE e `state`, em vez de implementação própria.

Justificativa: protocolos padronizados já tratam ataques conhecidos (interceptação de código, CSRF) e evitam que o [sistema] manipule a senha do provedor externo.

8. Login de dispositivo, local ou horário incomum deve gerar verificação adicional (autenticação adaptativa).

Justificativa: aplica Zero Trust na prática, já que um login válido de um contexto suspeito ainda pode ser um invasor.

9. A recuperação de senha deve usar link de uso único com expiração curta e enviado só ao e-mail cadastrado.

Justificativa: o fluxo de "esqueci a senha" é um caminho comum de invasão de contas quando é fraco.

B. Regras de autorização (o que pode fazer)

10. Princípio do menor privilégio: cada perfil recebe só as permissões necessárias para sua função.

Justificativa: limita o estrago se uma conta for comprometida e reduz erros acidentais no [sistema].

11. O acesso é controlado por papéis (RBAC), como Administrador, Editor e Usuário, nunca por permissões atribuídas individualmente.

Justificativa: facilita manutenção e auditoria e evita que permissões "esquecidas" se acumulem.

12. Dados e ações críticos de [tipo de dado] devem ter regras adicionais por atributo (ABAC), como setor, horário ou localização.

Justificativa: o papel sozinho é grosseiro. Atributos permitem, por exemplo, que apenas o setor responsável acesse certo dado.

13. A autorização deve ser validada no servidor a cada requisição, nunca apenas escondendo botões na interface.

Justificativa: um usuário pode chamar a API diretamente. Sem validação no back-end, ele acessa o que a tela não mostra (falha de controle de acesso, a nº 1 do OWASP Top 10).

14. Ações sensíveis (excluir dados, alterar permissões, exportar relatórios) exigem reautenticação.

Justificativa: confirma que quem está no teclado é o dono da sessão antes de operações irreversíveis.

15. Separação de funções: quem aprova uma ação crítica não pode ser quem a executa.

Justificativa: reduz fraude e erro interno, pois exige que duas pessoas colaborem para um abuso.

C. Ciclo de vida, auditoria e privacidade

16. Acessos devem ser revisados periodicamente (ex.: a cada trimestre) e revogados imediatamente quando a pessoa sai do projeto ou da função.

Justificativa: contas órfãs e permissões antigas são portas abertas. Se o [sistema] tiver muitos usuários, o ideal é automatizar com SCIM.

17. Contas administrativas e acessos ao servidor/banco devem ser isolados, com acesso temporário e registro completo (PAM).

Justificativa: administradores têm o maior poder de dano. Controlar e registrar o uso desse acesso limita vazamentos.

18. Todo evento de acesso (login, falha, mudança de permissão, acesso a dado sensível) deve gerar log protegido contra alteração.

Justificativa: sem logs não há como detectar ataques nem provar o que aconteceu.

19. Tráfego e tokens devem ser protegidos com HTTPS/TLS e cookies com flags `Secure`, `HttpOnly` e `SameSite`.

Justificativa: impede interceptação de credenciais em trânsito e roubo de sessão por scripts maliciosos.

20. O usuário deve registrar consentimento sobre uso de seus dados e poder consultá-lo ou revogá-lo (LGPD).

Justificativa: o [sistema] trata dados pessoais e a LGPD exige base legal e transparência. O registro vincula identidade e escolhas de privacidade, com trilha de auditoria.

O que mudou em relação ao texto original

- **Removido:** Unified ID 2.0, Dark Web Monitoring, verificação de idade e Gov.br. São muito específicos e só fazem sentido se o sistema tiver publicidade, conteúdo restrito ou login via CPF. Se tiver, dá para reincluir com justificativa.
- **Transformado em regra:** SAML, SSO e CIAM eram tecnologias. Se o projeto usa algum deles, vira regra do tipo "O sistema deve usar SSO para...". Se não usa, não precisa.

Fontes sugeridas

OWASP Top 10, OWASP ASVS, NIST SP 800-63B, NIST SP 800-207 (Zero Trust) e a LGPD. Confira os detalhes nos documentos originais antes de citar, pois números e versões podem conter erros.